

Cyber Security GRC Case Study



CareConnect Ltd

(Fictional Organisation)

Pruthviraj Patil

17/04/2026

Executive Summary

In this report, there will be a high-level cyber security assessment of CareConnect Ltd., a fictional company operating in the UK as a healthcare organisation processing sensitive data on patients and within the organisation. In addition, this paper will examine cyber security risk identification, control area assessment, and identity and access management.

This report will take into consideration the principles of security and those associated with the CIA Triad. As a result, the risks highlighted include unauthorised access to patient information, phishing attacks against the employees, and possible data loss through a lack of backups.

This review emphasizes the significance of efficient governance, risk management, and appropriate access control within the organization. Access control and asset visibility become particularly relevant in terms of risk mitigation.

It should be noted that the most important recommendations are as follows: the introduction of more powerful access control tools (e.g., Multi-Factor Authentication), periodic access reviews, enhanced security awareness training for employees, and asset inventories that are always updated.

In general, the above review clearly shows how crucial GRC principles are for ensuring the security of patients' information.

Company Overview

CareConnect Ltd. is a hypothetical company based out of the United Kingdom that represents both an NHS and private care provider setting. The company provides healthcare services in the form of patient support and remote consultation.

The company stores various types of sensitive data, including patient records, personal identifying information (PII), employee records, and communications between employees. Given the sensitivity of such data, it is crucial for the protection thereof.

Various systems help areConnect Ltd operate efficiently. Among these systems are electronic records for patients, email and communications tools, work computers provided to employees, and identity and access management systems used by the organisation to restrict user access to critical data.

From a regulatory standpoint, the company is subject to data protection laws such as the UK General Data Protection Regulation. The company should put necessary safeguards in place to prevent any breaches of the protected personal information.

Due to the nature of the operations of areConnect Ltd, the company should have strong governance processes in place, along with sound risk management and information security practices.

Scope of Assessment

This assessment has been carried out to conduct an evaluation of major cyber security risk areas in CareConnect Ltd., a fictional healthcare company in the United Kingdom that processes sensitive information related to patients and the company itself. Scope of the current assessment includes identification and analysis of major areas for the purposes of this exercise, reflecting the type of review conducted by a Junior GRC Analyst.

The purpose of the current assessment is to identify risks associated with cyber security issues; assess control areas; and make recommendations to enhance cyber security capabilities of the organization. This assessment will be conducted in accordance with industry standards and will focus on protecting sensitive information through confidentiality, integrity, and availability.

Scope of this assessment covers the following important topics:

Identification and Assessment of Risks:

An effective process is used to recognize possible threats for cyber security that could affect business activities and resources. Threats are assessed for probability and severity taking into account their effect on crucial business processes and resources.

Practices of Asset Management:

This assessment takes a look at the process of identification and management of organisational assets. This also covers the brief description of important organisational systems like database containing patients' records, employees' equipment, and internal communication system. Importance of having an updated list of organisational assets is discussed.

Access Control Controls for Identity and Access Management (IAM):

The review assesses control measures which are in place to limit access to important systems and data. It covers issues such as methods of authentication, user access levels, and management of privileged user accounts. The contribution of controls like MFA to limit unauthorized access will be discussed.

Audit Methodology for High-Level Audit Perspective:

The concept of a high-level audit perspective is adopted when conducting the audit on the controls. This involves examining how security controls will be evaluated as far as their design, implementation, and effectiveness.

What needs to be emphasized at this point is that the above analysis involves only a conceptual level of evaluation and review. No technical test or system configuration, no data validation have been included here.

The current report is a hypothetical case study that has been prepared for illustrative purposes only. But at the same time, the approach used in assessing GRC in a healthcare environment mirrors the real-life processes employed in the cyber security risk and compliance assessment area.

Risk Assessment

Risk assessment has been done on CareConnect Ltd in order to find out what cyber security risks can exist and how they would affect the organization. This risk assessment is meant to examine the effects that the identified risks might have on the CIA Triad.

These risks have been assessed depending on their effect on the CIA Triad in order to ensure that this risk assessment is conducted systematically and in line with the cyber security industry standards. The identified risks have been examined depending on the probability of their occurrence and the business impact they would have.

Risk Assessment Table

Risk ID	Risk Description	CIA Impact	Likelihood	Impact	Risk Level	Reasoning
R1	Unauthorised access to patient data	Confidentiality	Medium	High	High	Weak or insufficient access controls may allow unauthorised users to access sensitive patient records.
R2	Phishing attack targeting staff	Confidentiality / Integrity	High	High	High	Staff may fall victim to phishing emails, leading to credential compromise or unauthorised system access.
R3	Data loss due to inadequate backup processes	Availability	Low	High	Medium	Lack of regular backups or poor backup management could result in permanent data loss during system failures.

Risk Assessment Explanation

As mentioned above, there are several risks which pose serious threat to the company. First of all, unauthorised access to data is likely to occur because patient information is highly sensitive and thus needs to be protected properly.

The phishing attack is another risk that poses danger because it occurs frequently and mostly within healthcare organisations where employees use email communication. Employees must be informed about this kind of cyber security threat so that they can avoid being victims of such attacks.

Finally, there is a risk related to losing the data. Although this happens rarely, there is a possibility that if the organisation doesn't back up its data properly, it might end up losing its files.

Thus, in conclusion, one should note that these threats indicate the necessity of using proper access control measures, increasing awareness among users, and ensuring the safety of the data.

Risk Register

The risk register captures a comprehensive listing of the identified risks within CareConnect Ltd, together with their likelihood, impact, risk level, and proposed controls. The information captured in the risk register facilitates risk prioritization and decision-making regarding risk management.

Risk Register Table

Risk ID	Risk Description	Likelihood	Impact	Risk Level	Recommended Control	Control Owner
R1	Unauthorised access to patient data	Medium	High	High	Implement strong access controls including Multi-Factor Authentication (MFA), role-based access control (RBAC), and regular user access reviews	IT / Security Team
R2	Phishing attack targeting staff	High	High	High	Conduct regular staff security awareness training, implement email filtering solutions, and enforce phishing simulation exercises	IT / HR Team
R3	Data loss due to inadequate backup processes	Low	High	Medium	Implement regular automated backups, test backup restoration processes, and ensure secure storage of backup data	IT Team

Risk Register Explanation

The Risk Register identifies the top risks to CareConnect Ltd and the necessary control actions that need to be implemented in order to mitigate their occurrence.

Unauthorized access to the company's records of patients poses the greatest danger. The risk can be mitigated by ensuring access controls, such as Multi-Factor Authentication and role-based access controls.

Phishing attacks pose a risk owing to the possibility that they may occur and because they pose both a threat to the confidentiality and integrity of the systems. This risk could be managed through prevention and user education.

Data loss is one of the most serious risks for organizations since, if a failure occurs without backup, the data would be lost and operations would cease.

In summary, it can be said that the implementation of the suggested controls will contribute to minimizing the associated risk factors.

Asset Management Overview

Asset management is very important for visibility into systems, devices, and data in the organization. Proper asset management helps to understand risks and apply appropriate controls in order to be able to respond to security incidents.

The company uses various kinds of digital and physical assets to deliver services. Such assets involve systems that contain sensitive data and other information; various devices owned by employees and needed to work daily; and means of communication that are essential for carrying out services.

To have better visibility into assets, the organization uses the CMDB. CMDB is a database where asset data is collected and stored. It helps to manage and track various assets in the organization.

Proper asset management helps to discover vulnerabilities, apply asset controls, and conduct risk assessment. The lack of asset management may cause security problems, such as unauthorized devices in the network and unprotected systems that contain sensitive data.

Key Assets Identified

Asset Name	Asset Type	Description	Sensitivity Level	Owner
Patient Record System	Digital	Stores and manages patient health records and personal data	High	IT Team
Staff Laptops	Physical	Used by staff to access internal systems and perform daily tasks	Medium	IT Team
Email System	Digital	Supports internal and external communication between staff and stakeholders	High	IT Team

Asset Management Explanation

Assets mentioned above are considered essential elements of CareConnect Ltd. Systems like the patient record database and emails system contain extremely sensitive data, thus calling for proper security controls. The staff's laptops are regarded as medium-sensitive, but this is not to mean that they cannot be exploited through security vulnerabilities.

It is necessary to ensure all assets have been added in the CMDB to improve visibility of these assets as well as the ability to implement appropriate security controls considering their sensitivity and level of risk posed by each asset.

In conclusion, the importance of having a good asset management plan cannot be over-emphasized.

Identity and Access Management (IAM) Review

Identity and Access Management (IAM) controls were examined for CareConnect Ltd to determine if suitable controls exist to make sure that access to their highly sensitive systems is available to authorized users only. Due to the very nature of the business and the highly sensitive information that CareConnect Ltd works with, access control plays a pivotal role in preventing any security breach.

Some of the most important aspects are discussed below.

Access Control Review

Access controls have been evaluated to make sure that access rights to the system are given to people based on their roles and responsibilities. Role-based access control must be employed to provide access to those things which are only needed by people to perform their tasks. This minimises the chance of providing more access than required to sensitive applications like patient data bases.

Moreover, user accounts need to be managed effectively during their entire life cycle from account creation through modifications until their removal once the staff member leaves the organization.

Authentication Controls

The authentication process was evaluated in terms of how the users authenticate themselves while using the systems. It is highly suggested that Multi-Factor Authentication be implemented as it offers another level of protection besides the password. Multi-Factor Authentication limits the chances of someone gaining unauthorized access, especially if the user's credentials have been compromised through phishing attacks or other forms of intrusion.

Privileged Access Management (PAM)

Privileged accounts, like those for administrative personnel, have more powerful access privileges, thus posing a higher risk from the security point of view. The audit underscores the need for appropriate Privileged Access Management measures in handling such accounts.

These include restricting the number of privileged accounts, implementing stringent authentication processes before granting administrative access, and monitoring any actions carried out through such accounts. Otherwise, the misuse of privileged accounts may result in serious security breaches.

Access Review and Monitoring

Continuous access review is key in ensuring that the users are holding on to the right amount of access required for them to carry out their tasks. Apart from this, there is need to monitor the activities of the users especially those who have administrative access.

IAM Review Summary

As per the IAM analysis, it is vital for safeguarding confidential healthcare information that appropriate measures are adopted to provide robust access control measures with effective authentication and privileges. The use of appropriate security controls like MFA and proper access reviews will help ensure that unauthorized access is minimized within the organization.

Audit Approach

The auditing approach of CareConnect Ltd will enable the auditor to determine the adequacy of important cyber security controls and the presence of gaps in controls that might present risk for the company. It will adhere to an established methodology that takes into account current standards in the industry and will be focused on control design as well as effectiveness of controls.

An auditing approach will involve the analysis of the design of controls and their effectiveness in order to check whether controls have been correctly put in place and whether they function effectively. It will also entail determining whether controls are designed in response to risks that have been identified.

The auditing approach will be in accordance with the principles of the Three Lines of Défense Model.

- **First Line of Defence (Operational Management):** This is tasked with putting into practice and ensuring controls on a daily basis. For CareConnect Ltd, examples of such controls include those managed by IT departments.
- **Second Line of Defence (Risk and Compliance Functions):** Monitors and ensures proper policies, standards, and procedures exist. This line oversees compliance with the company's policies and any regulatory requirements.
- **Third Line of Defence (Internal Audit):** Independent evaluation of the efficiency of controls and governance procedures. Activities of internal audit involve assessment of the efficiency of controls and their improvement.

The audit methodology will also cover control area assessment, including reviewing controls for Identity and Access Management, asset management, and data protection measures. The effectiveness of the controls, such as access controls, authentication methods, and asset tracking procedures, will be examined and evaluated.

Additionally, control weaknesses such as unnecessary user permissions, inadequate periodic access evaluations, and insufficient asset inventories will be identified and noted to provide support for making recommendations for improvement.

In this case, it should be understood that this type of audit process is more conceptual in nature and does not include any technical assessment or system verification. However, it is an accurate representation of the basic principles employed in a cyber security audit.

Recommendations

Following a risk assessment and control review carried out at CareConnect Ltd, the following recommendations have been made to improve the security position of the company:

- **Implement Multi-Factor Authentication (MFA):** Incorporate Multi-Factor Authentication into all critical processes, especially for those that contain sensitive information related to patients as well as any other administrative process. This will greatly help minimize chances of unauthorized access.
- **Enhance Staff Security Awareness Training:** Provide cyber security awareness training for staff to improve their ability to identify phishing emails, handle confidential information securely, and use organizational systems safely. This will lower the risk of social engineering attacks succeeding.
- **Maintain an Accurate Asset Inventory:** It is important to have an asset inventory that is kept up-to-date and maintained. This can be done by creating an asset inventory through a CMDB.
- **Conduct Regular Access Reviews:** Perform access reviews periodically in order to ensure that access privileges are consistent with roles and responsibilities. This will assist in eliminating unnecessary access and privilege escalation.

Conclusion

From this assessment, it is clear that good governance, effective risk management, and sound access control policies are necessary measures for ensuring the confidentiality of information within CareConnect Ltd. Risks such as unauthorized access, phishing attacks, and data losses are some of the challenges that necessitate the use of cyber security principles.

Implementation of controls such as MFA, sound asset management principles, and timely access reviews will go a long way in securing the organization from potential threats.

Additionally, a risk-based approach that adheres to recognized principles like the CIA Triad makes decision making easier while ensuring that assets are sufficiently secured.

In summary, this case analysis illustrates how good GRC principles are applied when it comes to identifying risks and evaluating control measures.